

TLP:CLEAR

INCIDENT REPORT

XWorm V7.1 — spoofed-FESCO "signed contract" logistics phishing campaign

XWorm • RAT • Phishing • Maritime Logistics • Config Extraction

Parameter	Value
Incident date	2026-07-06 (interception); campaign active 2026-06-18 – 2026-07-06
Report date	2026-07-06
Classification	Malware delivery / Commodity RAT
Threat level	HIGH
Malware family	XWorm V7.1
C2	109.248.150[.]234:443
Source	Inbound email honeypot gateway (aggregated sensor telemetry)

1. Executive Summary

An inbound email honeypot gateway we operate intercepted a phishing message spoofing FESCO (PAO Vladivostok Commercial Sea Port, a Russian maritime carrier), using the subject line "Signed Contract". The message carried a ZIP archive disguised with a fake ".r11" extension — designed to look like a RAR volume — that in fact contained a single Windows executable, Contract9021_06_07_26.exe, masquerading as a signed contract document. Sender authentication failed: SPF = Fail, with the true originating host at 89.108.121[.]15 (HELO rpnmail.fmf.ru) unrelated to FESCO, while the envelope-from address was forged to read abersenyov@fesco[.]com.

Detonation of the payload in an isolated sandbox identified the XWorm remote access trojan (RAT), version 7.1, and yielded a full runtime configuration: command-and-control host 109.248.150[.]234 over TCP/443, an AES traffic-encryption key, and a mutex value. Pivoting on the extracted C2 indicator across public sandbox and threat-intelligence repositories revealed an active, ongoing campaign of at least 33 related samples sharing the same infrastructure, all themed around maritime logistics documentation — bills of lading (HBL/MBL), shipment pre-alerts, and signed contracts — with delivery waves observed since at least 2026-06-18.

The combination of a real, verifiable carrier brand (FESCO), industry-specific lure documents, and a masqueraded archive extension indicates a targeted effort against logistics and maritime freight organizations rather than opportunistic spray. XWorm is a widely available commodity RAT/stealer offered through underground builder kits; this campaign shows no unique tooling beyond standard XWorm capabilities, but its persistence (multi-week campaign, dedicated C2, thematic consistency) suggests a moderately resourced, financially or espionage-motivated actor targeting the shipping/freight-forwarding sector.

2. Attack Chain

#	Stage	Description
1	Preparation	Spoofed sender identity crafted to impersonate FESCO staff; lure themed as a "signed contract" targeting logistics/maritime correspondents.
2	Delivery	Phishing email delivered with a ZIP archive attachment disguised via a fake ".r11" extension, mimicking a RAR archive volume to evade extension-based filtering.
3	Execution	Victim opens the archive and runs the enclosed executable, Contract9021_06_07_26.exe, believing it to be a contract document.
4	Unpacking / Injection	XWorm payload (SmartAssembly .NET packer) unpacks and injects into a process via SetThreadContext.
5	Defense Evasion	Windows Defender disabled via PowerShell and registry modification; host country-code checked as an anti-analysis/geofencing gate.
6	Persistence	Registry Run key and Startup-folder entries established; payload installed at %AppData%\bin.exe.
7	Collection	Outlook profile data, email credentials, and browser data/cookies harvested.

8	Command & Control / Spread	TLS beacon to 109.248.150[.]234:443; additional lateral spread via removable media through USB.exe.
---	----------------------------	---

3. Email & Delivery Analysis

3.1. Message Headers

Parameter	Value	Assessment
From	ABersenyov@fesco.com	Spoofted
Return-Path / envelope-from	abersenyov@fesco.com	Forged to match From
Subject	Signed Contract	Contract lure
Body (summary)	"Please review the attached signed contract", signed "Bersenyov Andrey Sergeevich, deputy head of heat and water supply department, PAO VMTP, Vladivostok"	Plausible internal-staff persona

3.2. Authentication

Check	Result	Details
SPF	Fail	client-ip = 89.108.121[.]15, HELO = rpnmail.fmf.ru — not authorized by, or associated with, fesco.com
DKIM	none	No valid signature present
DMARC	not aligned	Header-From domain not aligned with authenticated sending infrastructure

A mail gateway enforcing SPF/DKIM/DMARC with a reject or quarantine policy would have blocked or flagged this message. Our honeypot gateway retained it prior to any such filtering for analysis purposes.

4. Malicious Attachment

4.1. Archive Masquerade

Attribute	Value
Filename	Contract9021_06_07_26.r11
Declared Content-Type	application/zip
File magic	50 4B 03 04 (PK\x03\x04 — ZIP local file header)
Size	766,309 bytes
Assessment	The ".r11" extension is designed to visually and semantically suggest a segmented RAR archive volume, despite the file being a plain ZIP by signature. This masquerade (MITRE T1036.008) is intended to bypass filters and analyst heuristics keyed on executable or recognized archive

	extensions.
--	-------------

4.2. Enclosed Executable

Attribute	Value
Filename	Contract9021_06_07_26.exe
Size	852,992 bytes
Format	PE32 (MZ header), .NET assembly
Packer	SmartAssembly (.NET obfuscator/packer)
Archive contents	Single file — no decoy document is present alongside the payload

5. XWorm Payload & Extracted Configuration

5.1. Runtime Configuration (from detonation)

Field	Value
Malware family	XWorm
Builder version	V7.1 (config marker 5.0)
C2 host:port	109.248.150[.]234:443
Traffic AES key	bK5bLIZIB9durXZWd5PDkvR0hpNHk04+uqD7mNo2KtY=
Mutex	70vLmgcqMEnUJOeL
Install path	%AppData%\bin.exe
USB-spread module	USB.exe

5.2. Observed Behavior

- Process injection into unbacked memory regions via SetThreadContext.
- AMSI enumeration/probing prior to further execution stages.
- Windows Defender disabled through PowerShell commands and direct registry modification.
- Persistence via Registry Run key and Startup-folder entry, payload copied to %AppData%\bin.exe.
- Credential and data theft targeting Outlook profiles, mail client data, and browser-stored data/cookies.
- Anti-sandbox checks based on hardware identifiers and presence of an IDE disk interface.
- Country-code / locale check consistent with geofencing or target validation.
- Self-propagation to removable media via a dedicated USB.exe component.

6. C2 Infrastructure

Attribute	Value
C2 IP	109.248.150[.]234
Port	443/TCP (TLS)
ASN / Hosting	AS203557 SIA RixHost / DATA CLUB-NL — Latvian-registered provider,

	datacenter presence in the Netherlands (Zwolle/Lelystad area)
Host OS	Windows Server 2019
Exposed services	TCP/135 (RPC), TCP/3389 (RDP), TCP/5985 + TCP/47001 (WinRM) — consistent with a manually administered operator machine rather than an automated bulletproof panel; port 443 is not exposed to generic scanners and appears to serve the C2 panel only on demand
AbuseIPDB	0/100 confidence of abuse (under-reported)
ThreatFox (abuse.ch)	Tracked as an XWorm botnet C2 since 2026-06-18, confidence 75
Auxiliary stager	185.27.134[.]124 — observed delivering a .vbs-based loader variant
Cloudflare-fronted resources	104.21.36[.]120, 172.67.193[.]253

7. Campaign Pivot & Victimology

Pivoting on the extracted C2 indicator (109.248.150[.]234) against public sandbox and malware-intelligence repositories surfaced at least 33 related samples sharing the same command-and-control infrastructure. Lure themes across the cluster are consistently tied to maritime logistics and freight operations: signed contracts, House and Master Bills of Lading (HBL/MBL), and shipment "pre-alert" notifications sent to consignees ahead of cargo arrival.

The spoofed sender identity — a Russian maritime carrier (FESCO) — is directly aligned with this thematic cluster, indicating the campaign specifically targets logistics, freight-forwarding, and shipping-adjacent organizations rather than a generic, industry-agnostic phishing blast. Delivery waves associated with this cluster have been observed since at least 2026-06-18, indicating a sustained, multi-week operation rather than a single opportunistic mailing.

8. Indicators of Compromise

Type	Value	Description
IP (C2)	109.248.150[.]234:443	XWorm command-and-control (AS203557 SIA RixHost / DATA CLUB-NL, NL)
IP (stager)	185.27.134[.]124	Auxiliary stager delivering a .vbs loader variant
IP (sender)	89.108.121[.]15	True originating IP of the spoofed FESCO email (SPF Fail, HELO rpnmail.fmf.ru)
Domain (spoofed)	ABersenyov@fesco[.]com	Forged sender address impersonating FESCO staff
SHA256	37f7127bcae8388c61432dc2d46b0df36cb33	Contract9021_06_07_26.exe (XWorm)

	690ebbc5b725b28b33dfb145d4b	dropper)
MD5	5053320a66a5c4989c44a932a8720b7d	Contract9021_06_07_26.exe
SHA256	e8e901194d86b29166d6028cc97d3b7559ecff413f20cd7b7f84601c2d9f2709	Contract9021_06_07_26.r11 (ZIP archive masquerading as RAR)
SHA256	f9183d461a9ef71e1a0a97ddef54f5a785c3d4fa1ac6cb979a82206a52037928	Extracted payload / config-bearing module
SHA256	7776706d26fb2dfd7cb96910810bb4c3a02b343a228035a0ca4db3ccf8e4d26a	Related sample — same C2 cluster
SHA256	d4bc7db58a0b6207d2d24336833ae73a8cac77bf9f6bfe68ad1c33b52f990d0d	Related sample — same C2 cluster
SHA256	6bdd98cecb7ecf8240b8fd57497a952dd2850075339b3932f4e2c2285dda00c6	Related sample — same C2 cluster
SHA256	c8c385c10b1586728318f43b9dcafecfd46d8d6000984fe489bb1d219ea8b4f9	Related sample — same C2 cluster
SHA256	70c2fe27f67d5bd45f18c826a1dc1f852fa86b2de8271151a7b8c4d6d58f34d7	Related sample — same C2 cluster
SHA256	fe126b87922ff8049c4b19d6588324a3bb4874020b943e86de176445ebe7c7b9	Related sample — same C2 cluster
Mutex	70vLmgcqMEnUJOeL	XWorm mutex value
AES key	bK5bLIZIB9durXZWD5PDkvR0hpNHk04+uqD7mNo2KtY=	Traffic encryption key extracted from config
File path	%AppData%\bin.exe	Persistence install path
File path	USB.exe	Removable-media spreader component

9. MITRE ATT&CK Mapping

Tactic / Technique	ID	Application
Spearphishing Attachment	T1566.001	Delivery of the disguised ZIP archive by email
Malicious File	T1204.002	Victim execution of the enclosed .exe disguised as a contract
Masquerade File Type	T1036.008	ZIP archive renamed with a fake ".r11" extension to impersonate a RAR volume
Process Injection	T1055	SetThreadContext injection into unbacked memory
Registry Run Keys / Startup Folder	T1547.001	Persistence via Run key and Startup folder

Scheduled Task/Job	T1053.005	Scheduled task used for persistence/execution
Impair Defenses: Disable or Modify Tools	T1562.001	Windows Defender disabled via PowerShell and registry
Command and Scripting Interpreter: PowerShell	T1059.001	PowerShell used for defense evasion
Replication Through Removable Media	T1091	USB.exe component for spreading via removable drives
Steal Web Session Cookie	T1539	Theft of browser-stored cookies/session data
Virtualization/Sandbox Evasion	T1497	Hardware ID and IDE-disk based anti-analysis checks
Encrypted Channel	T1573	AES-encrypted C2 traffic over TLS on port 443

10. Recommendations

Immediate Actions

- Block the C2 host 109.248.150[.]234 and the auxiliary stager 185.27.134[.]124 at network egress/firewall/DNS layers.
- Load the listed file hashes into EDR/AV and mail-gateway attachment-blocking rules.
- For logistics and maritime organizations: treat unsolicited "contract", "bill of lading", or "pre-alert" emails bearing archive attachments with heightened scrutiny.
- Configure mail gateways to detect and quarantine archive attachments where the declared extension does not match the file's true signature (e.g., ".r11"/".rNN" files that are in fact ZIP by magic bytes).

Long-term Mitigations

- Enforce SPF, DKIM, and DMARC with a reject (or at minimum quarantine) policy — this specific message failed SPF and would have been filtered by a properly configured mail system.
- Monitor endpoints for XWorm-characteristic behavior: PowerShell-driven Defender configuration changes, unexpected Run-key entries pointing to %AppData%\bin.exe, and outbound TLS connections to non-standard hosts on port 443.
- Restrict or monitor use of removable media in environments handling sensitive logistics documentation, given the observed USB-spread capability.
- Maintain awareness that XWorm is a widely distributed commodity RAT/builder kit; presence of this family does not by itself indicate a sophisticated or state-linked actor, but sustained thematic campaigns against a specific sector warrant continued monitoring.

11. References

- ThreatFox (abuse.ch) — XWorm botnet C2 tracking for 109.248.150[.]234, tracked since 2026-06-18.
- MITRE ATT&CK — techniques referenced in Section 9 (attack.mitre.org).
- Public malware sandbox and reputation services used for C2 pivot and sample clustering.

TLP:CLEAR — This document may be distributed without restriction.